

 **API key connected**

● Ready to analyze · Key stored locally in your browser

Disconnect



Cloud Network Security Advisor

AI-powered security posture analysis · gap detection · hardening recommendations · 90-day action plan

🔗 NETWORK TOPOLOGY & ENVIRONMENT

Enterprise private cloud running VMware Cloud Foundation (VCF) across 3 data centers. North-south traffic managed by a traditional perimeter firewall with basic ACLs. East-west traffic between workloads is largely flat with no microsegmentation applied. Remote workforce access via legacy VPN with no MFA enforced. No consistent network monitoring or visibility into lateral movement between workloads. A recent merger added 2,000 new endpoints with unknown security posture integrated into the same flat

🔍 CURRENT SECURITY TOOLS

☒ VMware NSX

☐ NSX ALB / Avi

☐ SD-WAN

☐ IDS / IPS

☐ Zero Trust

☐ PAM

☐ vDefend ATP

☐ SASE

☒ Traditional Firewall

☒ SIEM

☐ EDR / XDR

☐ None currently

📋 COMPLIANCE REQUIREMENTS

☒ NIST CSF

☒ SOC 2

☐ HIPAA

☐ GDPR

☐ ISO 27001

☐ PCI-DSS

☐ FedRAMP

☐ None specified

⚙️ ENVIRONMENT CONTEXT

Environment type

Enterprise private cloud (VCF) ▼

Security maturity level

Defined — documented policies ▼

Analyze security posture

Load sample scenario

Clear

Analysis complete

Export to Excel

Critical risk · enterprise private cloud (VCF)

This VCF environment presents critical risk due to absence of microsegmentation, flat network topology, weak remote access controls, and unmanaged post-merger endpoints across multiple cloud environments. Lateral movement is essentially undetected and uncontrolled, creating material breach exposure and compliance violations against NIST CSF and SOC 2 requirements. Immediate implementation of NSX distributed firewalling, Zero Trust access controls, and comprehensive network visibility is essential to reduce risk.



Security gaps

12 identified · sorted by severity

SEVERITY	GAP / RISK AREA	DESCRIPTION	RECOMMENDED ACTION
Critical	Absence of Microsegmentation	East-west traffic between workloads operates on flat network with no identity or application-based segmentation policies. This violates NIST CSF PR.AC-5 (network segmentation) and enables unrestricted lateral movement post-breach, creating uncontrolled blast radius.	Deploy NSX Distributed Firewall with application-centric policies leveraging vSphere tags and VM attributes. Segment by workload criticality, function, and trust zone using NSX micro-rules. Implement at Layer 4-7 with deep packet inspection for encrypted traffic.
Critical	No Remote Access Zero Trust Controls	Legacy VPN without MFA exposes 2,000+ workforce endpoints to credential compromise and unauthorized access. No device posture checking, continuous authentication, or least-privilege access validation. Violates NIST CSF PR.AC-1 (identity management) and SOC 2 CC6.1.	Deploy vDefend ATP with SASE integration (Secure Web Gateway + Zero Trust Network Access). Mandate MFA with hardware keys for all remote access. Implement continuous device posture validation (OS patches, antivirus, encryption status) before network access grant.
Critical	Unmanaged Post-Merger Endpoints	2,000 endpoints from recent merger integrated into flat network with unknown security posture, patch levels, and endpoint detection. No inventory, no access controls, no visibility into their lateral movement. Represents highest-	Quarantine merger endpoints in separate NSX security group with restricted egress policies. Mandate EDR/vDefend ATP agent deployment before production access. Perform rapid CMDB inventory scan with vulnerability assessment. Implement 30-day hardening SLA with staged

SEVERITY	GAP / RISK AREA	DESCRIPTION	RECOMMENDED ACTION
		probability breach vector and compliance audit finding.	access restoration tied to remediation completion.
Critical	Multi-Cloud Policy Inconsistency	AWS and Azure workloads connected via site-to-site VPN with no consistent network policies, segmentation, or compliance enforcement. Creates policy blind spots and enables cloud-to-on-prem lateral movement without detection. Violates NIST CSF PR.AC-3 (access control enforcement).	Implement NSX Federation or equivalent policy orchestration to enforce consistent segmentation rules across VCF, AWS, and Azure. Use service mesh (Istio/Consul) for application-level policy enforcement in cloud workloads. Establish cross-cloud policy audit reviews on 30-day cadence.
Critical	Insufficient Network Visibility and Monitoring	No consistent monitoring of east-west traffic flows, no lateral movement detection, no threat correlation between SIEM and network telemetry. Inability to detect post-breach lateral movement violates NIST CSF DE.CM-1 (monitoring and anomaly detection) and defeats compliance requirements.	Deploy NSX Intelligence for traffic flow visualization and anomaly detection. Enable NetFlow/sFlow export from NSX to SIEM with full packet capture for suspicious flows. Implement behavioral baseline for east-west traffic and alert on deviations. Deploy network TAP or span sessions to enable threat intelligence correlation.
High	Weak Perimeter Firewall Architecture	Traditional perimeter firewall using basic ACLs cannot inspect encrypted traffic, enforce application-layer policies, or provide granular visibility. Provides false sense of security while east-west threats bypass entirely. Single point of failure for north-south traffic.	Implement active-active dual perimeter firewall with TLS decryption and SSL inspection. Deploy next-generation capabilities (IPS, threat prevention, sandbox analysis). Shift security focus to microsegmentation with NSX-T as primary enforcement boundary, relegating perimeter firewall to policy audit and threat intel.
High	No Application-Centric Policy Framework	Policies are network-centric (IP/port) rather than application-aware. Unable to enforce least-privilege access by application role, function, or business context. Cannot validate legitimate traffic from	Develop application-centric policy framework using NSX Security Tags based on business application, data sensitivity, and compliance zone. Implement DNS-based policy enforcement where applicable. Deploy vDefend ATP to correlate application behavior with network access for intent-based policy validation.

SEVERITY	GAP / RISK AREA	DESCRIPTION	RECOMMENDED ACTION
		malware-infected workload performing reconnaissance.	
High	Insufficient Compliance Automation	Manual compliance verification for NIST CSF and SOC 2 requirements across multi-cloud environment. No automated evidence collection for network segmentation, access controls, or change management. Audit readiness gap creates compliance risk and audit findings.	Implement NSX Compliance Dashboard with automated policy audit against NIST CSF and SOC 2 control baselines. Enable continuous compliance monitoring with automated remediation workflows. Integrate change management with policy versioning and approval workflow. Export compliance evidence to audit management platform.
High	No Zero Trust Identity Integration	Network access decisions based on network credentials only, not identity validation or context (user, device, location, time). No integration with identity provider (Okta, Entra ID) for continuous authentication. Workload-to-workload authentication is non-existent.	Integrate NSX with enterprise identity provider (vIDM, Okta, Entra ID) for identity-driven network access. Implement mTLS between workloads using service mesh or NSX-managed certificates. Enforce location-aware and risk-based access policies based on identity context and real-time threat intelligence.
Medium	Inadequate Incident Response Network Capabilities	No capability to rapidly isolate compromised workloads or segments network-wide without manual intervention. No automated response rules for threat detection correlations. Incident response timeline measured in hours rather than minutes.	Develop automated network isolation playbooks triggered by EDR/SIEM alerts (e.g., isolate workload to quarantine segment upon malware detection). Implement NSX Security Policy as Code (Infrastructure-as-Code) for rapid policy deployment during incident response. Conduct monthly IR tabletop exercises with network isolation scenarios.
Medium	Lack of Data Exfiltration Controls	No network-based data loss prevention for lateral movement or exfiltration attempts. Flat network allows unrestricted access to sensitive data stores. No encryption enforcement for data in transit between workloads.	Deploy NSX Distributed Firewall with DLP-enabled inspection for sensitive data flows (PII, credentials, payment data). Mandate encryption for all east-west traffic using NSX segment-based TLS. Implement data sensitivity tagging in NSX policies tied to workload classification (public, internal, confidential, restricted).

SEVERITY	GAP / RISK AREA	DESCRIPTION	RECOMMENDED ACTION
Medium	Insufficient Logging and Retention	Traditional firewall logs retention likely insufficient for forensics and compliance (NIST CSF DE.AE-3 requires audit trail retention). No centralized NSX policy change audit log. Limited historical visibility into policy violations and security events.	Implement centralized logging for all NSX policy decisions, changes, and enforcement events. Enforce minimum 90-day retention for forensics and 1-year for compliance. Enable NSX Flow Monitoring with extended attribute export for complete session reconstruction. Archive to long-term SIEM or SOAR platform with immutable retention.

Hardening recommendations			12 actions · sorted by priority
PRIORITY	RECOMMENDATION	WHAT TO DO	TOOL ALIGNMENT
Immediate	Deploy NSX Distributed Firewall with Default Deny East-West	Enable Distributed Firewall on all VMs in VCF environment with default-deny microsegmentation policy. Start with application profiling to understand legitimate traffic flows, then incrementally harden rules based on business application requirements. Implement Layer 4-7 inspection with vDefend ATP integration.	VMware NSX Distributed Firewall, NSX Application Rule Manager, vDefend ATP
Immediate	Establish Zero Trust Remote Access with SASE	Replace legacy VPN with SASE solution providing Zero Trust Network Access. Mandate MFA (hardware key preferred), continuous device posture validation (OS patches, encryption, EDR status), and just-in-time privilege elevation. Implement split-tunnel prevention and encrypted DNS.	vDefend SASE, vDefend ATP, Okta/Entra ID integration, Hardware MFA
Immediate	Quarantine and Audit Post-Merger Endpoints	Isolate 2,000 merger endpoints in restricted NSX security group with minimal egress access. Deploy EDR/vDefend ATP agent with agent-enforced policy. Execute rapid vulnerability and patch compliance scan. Implement 30-day hardening remediation plan with weekly compliance verification before production tier access granted.	NSX Security Groups, vDefend ATP, Vulnerability Scanning, EDR
Immediate	Implement NSX Intelligence for Threat Detection	Deploy NSX Intelligence appliance cluster to capture and analyze east-west traffic flows. Configure anomaly detection baselines for normal business traffic. Integrate with SIEM for alert correlation. Enable behavioral analysis to detect lateral movement and reconnaissance activity in real time.	NSX Intelligence, SIEM (Splunk/IBM QRadar/others), NetFlow export, Threat Intel feeds

PRIORITY	RECOMMENDATION	WHAT TO DO	TOOL ALIGNMENT
Short-term	Establish Multi-Cloud Policy Orchestration	Implement NSX Federation or equivalent policy orchestration platform to enforce consistent security policies across VCF, AWS, and Azure. Define policy as code in version control with approval workflow. Establish cross-cloud policy audit on 30-day cadence with automated compliance checking.	NSX Federation, Terraform/Ansible for IaC, Service Mesh (Istio/Consul for AWS/Azure)
Short-term	Deploy Identity-Driven Network Access Controls	Integrate NSX with enterprise identity provider (vIDM, Okta, Entra ID) for identity-centric policy enforcement. Implement mTLS between workloads using NSX certificate management or service mesh. Enforce continuous authentication with risk-based access decisions based on identity, device, location, and behavioral context.	NSX, Identity Provider (Okta/Entra ID/vIDM), Service Mesh, mTLS certificates
Short-term	Harden Perimeter Firewall with Advanced Threat Prevention	Upgrade traditional perimeter firewall to active-active dual configuration with TLS decryption, IPS/threat prevention, and sandbox analysis. Implement zero-day malware detection. Shift focus toward policy audit and threat intelligence rather than primary access control (which moves to NSX microsegmentation).	Next-generation Firewall (Fortinet/Palo Alto/Cisco ASA), TLS decryption, IPS, Sandbox analysis
Short-term	Implement Application-Centric Security Tagging	Develop taxonomy of security tags in NSX aligned to business applications, data sensitivity levels, and compliance zones (e.g., PCI, HIPAA, internal-only). Tag all VMs and network segments accordingly. Build NSX policies enforcing least-privilege access based on tags rather than IP addresses. Implement DNS-based policy enforcement where applicable.	NSX Security Tags, vCenter VM attributes, VMware Aria or Kubernetes labels for cloud workloads
Short-term	Enable NSX Compliance Automation Dashboard	Configure NSX Compliance Dashboard with automated audit against NIST CSF Identify/Protect/Detect/Respond/Recover and SOC 2 CC6 (logical access) control baselines. Enable continuous compliance monitoring with automated remediation workflows. Integrate change management and policy versioning. Export evidence to audit management platform for SOC 2 attestation.	NSX Compliance Dashboard, VMware Aria Automation for remediation, Audit management platform
Medium-term	Develop Automated	Create automated IR playbooks triggered by security alerts (EDR/SIEM detection of malware, suspicious lateral movement).	SOAR (ServiceNow/Palo Alto Cortex XSOAR),

PRIORITY	RECOMMENDATION	WHAT TO DO	TOOL ALIGNMENT
	Incident Response Orchestration	Define network isolation actions (workload quarantine to restricted segment, disable network adapters, suspend access). Implement policy-as-code for rapid policy deployment during incidents. Conduct monthly IR tabletop exercises.	vDefend ATP integration, NSX Policy-as-Code, Ansible automation
Medium-term	Implement Network-Based Data Loss Prevention	Deploy DLP-enabled inspection in NSX Distributed Firewall to detect sensitive data (PII, credentials, payment data) in lateral movement flows and exfiltration attempts. Implement data sensitivity tagging in policies aligned to workload classification. Mandate encryption for all east-west traffic using NSX segment-based TLS.	NSX Distributed Firewall with DLP, Data classification tools, Encryption key management (Thales/HashiCorp)
Medium-term	Establish Comprehensive Logging and Forensics Architecture	Implement centralized logging for NSX policy decisions, enforcement events, and changes with minimum 90-day forensics retention and 1-year compliance retention. Enable NSX Flow Monitoring with extended attributes for complete session reconstruction. Archive to immutable long-term storage. Establish log analysis runbooks for forensic investigation.	Central SIEM (Splunk/IBM QRadar), NSX Flow Monitoring, Elasticsearch/Splunk indexes, Log retention/archival policy

🔄 90-day action plan 5 phases			
#	PHASE	KEY ACTIONS	TIMELINE
1	Phase 0: Foundation & Preparation (Weeks 1-2)	› Conduct comprehensive network discovery and application profiling to understand legitimate east-west flows and dependencies › Establish NSX policy governance framework with approval workflow and change management integration › Procure and license NSX Intelligence, vDefend ATP SASE, and advanced perimeter firewall capabilities › Document current perimeter firewall baseline rules for reference during hardening › Schedule security awareness training for teams on Zero Trust architecture and microsegmentation concepts	🕒 Weeks 1-2
2	Phase 1: Critical Risk Mitigation (Weeks 3-6)	› Deploy NSX Distributed Firewall with default-deny policy on pilot security zone (non-production); validate application traffic flows › Implement SASE platform with MFA and device posture validation; pilot with 100 remote workers	🕒 Weeks 3-6

#	PHASE	KEY ACTIONS	TIMELINE
		› Isolate 2,000 post-merger endpoints in restricted NSX security group; deploy EDR/vDefend ATP mandatory agents › Deploy NSX Intelligence appliance cluster; establish baseline behavioral traffic profiles › Upgrade perimeter firewall to active-active dual configuration with TLS decryption; enable IPS/threat prevention › Export NSX policy decisions and enforcement events to SIEM; establish continuous compliance monitoring for NIST CSF controls	
3	Phase 2: Accelerated Rollout (Weeks 7-12)	› Expand NSX Distributed Firewall deployment to all production workloads; enforce application-centric policies with Layer 4-7 inspection › Complete SASE rollout to all 2,000+ remote workers; enforce MFA and continuous device posture validation › Complete hardening remediation of post-merger endpoints; restore production access based on compliance verification › Integrate NSX with enterprise identity provider (Okta/Entra ID); implement identity-driven network access controls › Deploy NSX Compliance Dashboard; configure automated audit against NIST CSF and SOC 2 baselines › Establish cross-cloud policy orchestration framework for AWS and Azure workloads; implement policy-as-code with version control	🕒 Weeks 7-12
4	Phase 3: Advanced Capabilities (Weeks 13-20)	› Implement mTLS between workloads using NSX certificate management; validate encrypted east-west traffic › Deploy DLP-enabled inspection in NSX Distributed Firewall for sensitive data detection and exfiltration prevention › Develop and test automated incident response playbooks with network isolation capabilities; conduct IR tabletop exercise › Implement NSX Flow Monitoring with extended attributes; establish forensic investigation runbooks › Deploy service mesh (Istio/Consul) for AWS and Azure workloads; enforce application-level policies across cloud providers › Develop application-centric security tagging taxonomy; tag all VMs and segments aligned to business applications and data sensitivity	🕒 Weeks 13-20

#	PHASE	KEY ACTIONS	TIMELINE
5	Phase 4: Optimization & Compliance (Weeks 21-26)	› Conduct comprehensive policy audit to identify and consolidate redundant rules; optimize performance › Perform SOC 2 readiness assessment with focus on network segmentation and access controls; remediate gaps › Establish monthly IR tabletop exercises and quarterly security architecture reviews › Implement continuous compliance monitoring with automated remediation; document evidence for audits › Conduct post-merger endpoint security audit; validate 30-day hardening SLA completion with zero exceptions › Complete NSX Federation or equivalent cross-cloud policy orchestration; validate consistent policy enforcement	🕒 Weeks 21-26